

Trabajo de Fin de Grado
Grado en Ingeniería Informática

Playbook de respuesta frente a acceso no autorizado con detección automatizada

Autor: Adrián Puyo Olías

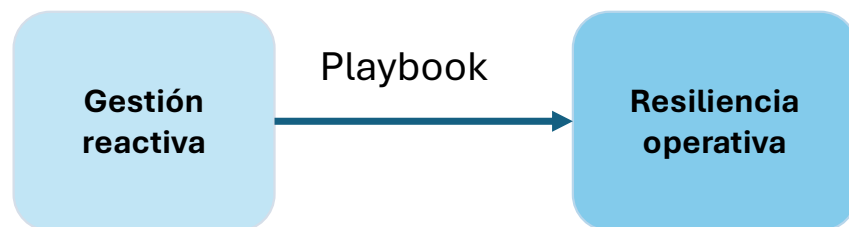
Director: Alfredo del Castillo Villalba

Índice

1. Contexto y problema
2. Objetivo del trabajo
3. Metodología
4. Desarrollo del playbook
5. Roles y responsabilidades
6. Automatización y demostración
7. Conclusiones

Contexto y problema

¿Se puede responder mejor a un acceso no autorizado si el incidente deja de gestionarse de forma reactiva y pasa a gestionarse de forma estructurada?



Cinco problemas de la respuesta reactiva

- 1 Estructuras heterogéneas entre tipos de incidente
- 2 Ausencia de criterios formales de diseño
- 3 Débil trazabilidad entre normativa y operación
- 4 Escasa preparación para la automatización
- 5 Dificultad para generar evidencias estructuradas

Objetivos del trabajo

Objetivo general

Diseñar un playbook de respuesta a incidentes de acceso no autorizado para entornos corporativos que integre buenas prácticas, requisitos normativos y capacidades de automatización.

Objetivos específicos

Analizar los modelos de respuesta y los playbooks corporativos existentes

Aplicar los requisitos normativos y estándares internacionales relevantes

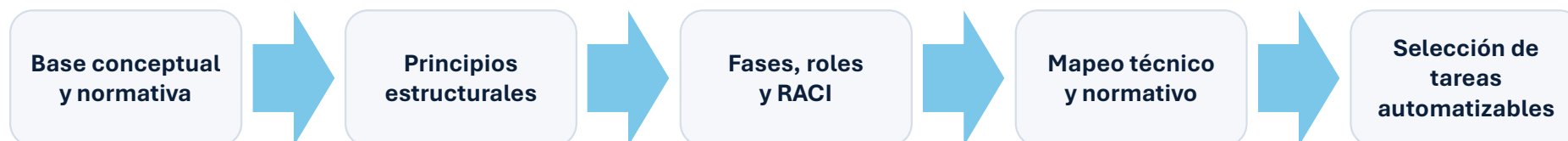
Definir fases, roles y trazabilidad

Probar una automatización funcional acotada

Desarrollar el playbook completo para el escenario de acceso no autorizado

Metodología

La metodología combina tres capas: principios de diseño, marcos de referencia y construcción operativa del playbook.



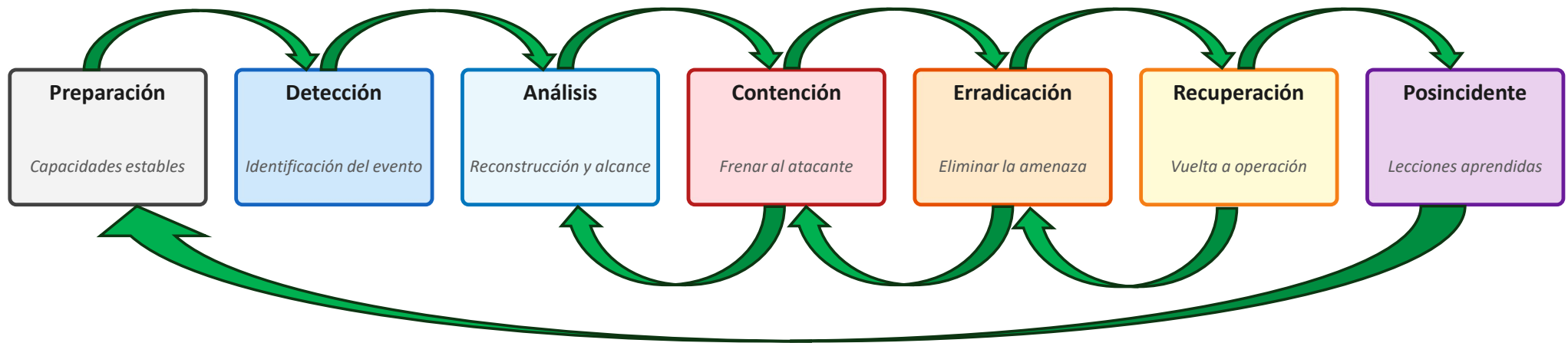
Principios estructurales



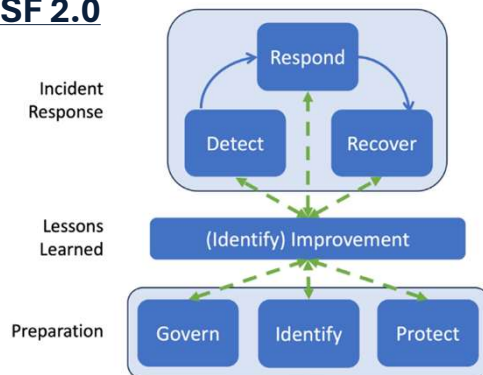
Marcos utilizados

NIST SP 800-61	NIS2
ISO/IEC 27035	RGPD
MITRE ATT&CK	ENS
DORA	CER

Desarrollo del playbook



Modelo de ciclo de vida de un incidente según CSF 2.0



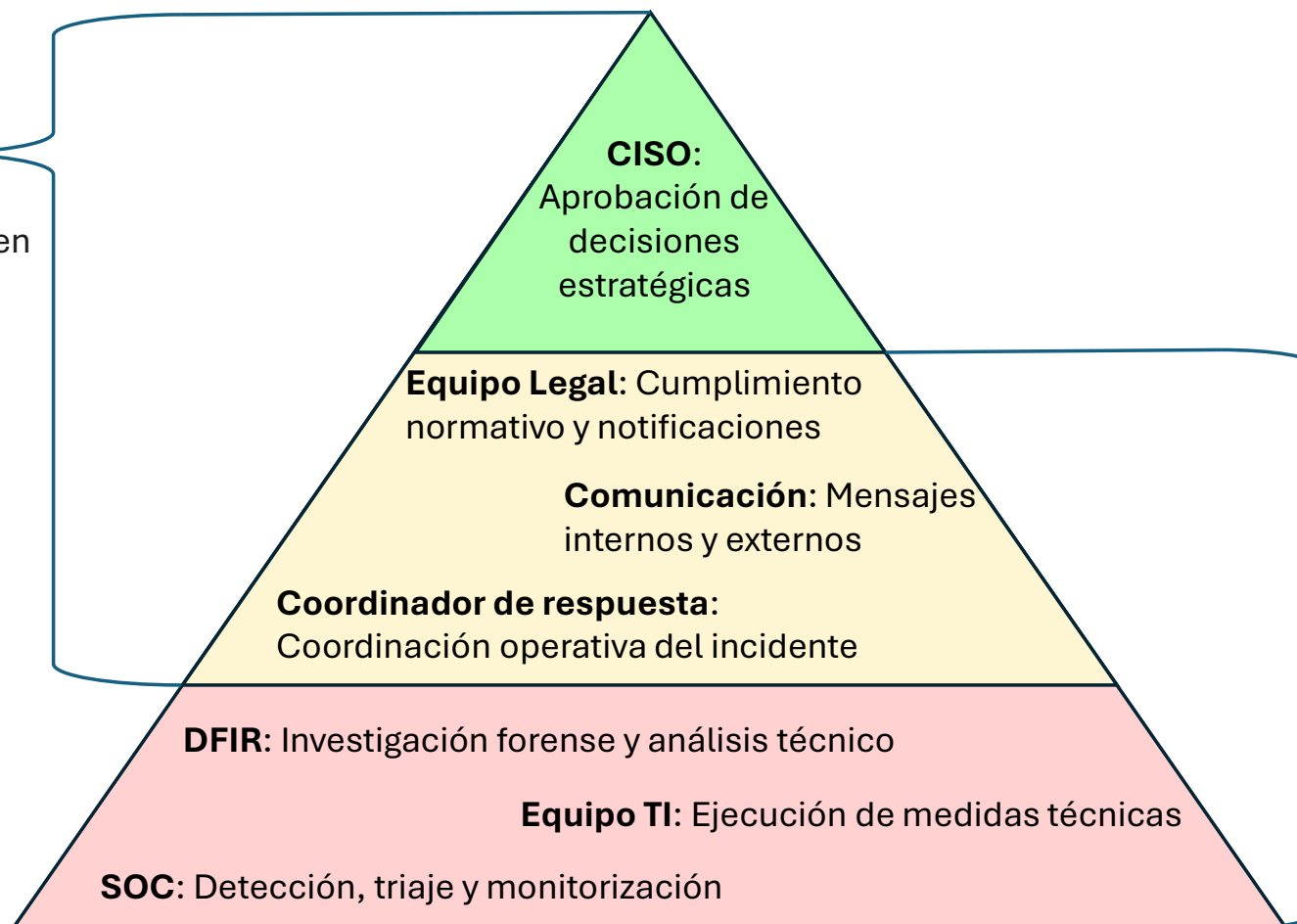
Componentes incluidos

- Criterios de activación y severidad.
- Acciones por fase y responsable.
- Matriz RACI para siete roles.
- Modelo de trazabilidad y evidencias.
- Mapeo con MITRE ATT&CK y normativa.

Roles y responsabilidades

Plano de Gobernanza:

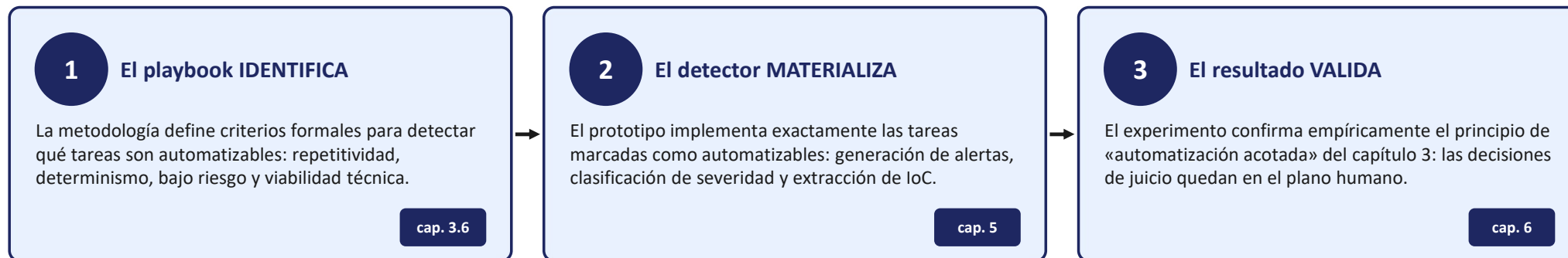
Decisiones de coordinación, supervisión y comunicación en paralelo.



Plano Operativo:

Acciones técnicas del equipo de respuesta sobre los sistemas afectados.

Automatización y demostración



Qué se automatiza concretamente

Fuerza bruta

≥5 fallos contra una misma cuenta desde una IP

Password spraying

Misma IP intenta acceder a varios usuarios

Compromiso confirmado

Acceso exitoso tras múltiples fallos previos

Qué se detecta tras los ataques

Fuerza bruta **Severidad alta**

15 intentos contra 'admin'
en 3,28 minutos

Password spraying **Severidad alta**

9 usuarios distintos
desde la misma IP

Compromiso confirmado **Severidad crítica**

Acceso exitoso a 'admin'
tras 15 fallos previos

Conclusiones



Aporta

- Metodología propia con 4 principios
- Playbook completo en 7 fases con RACI
- Mapeo doble: MITRE + 7 marcos normativos
- Prototipo de automatización funcional
- 5 problemas iniciales resueltos



Limitaciones

- Un solo tipo de incidente
- Sin validación en entorno corporativo
- Una sola fuente de datos
- Umbrales estáticos



Líneas futuras

- Extensión a otros incidentes
- Formalización en CACAO 2.0
- Integración con SOAR real
- Detección con líneas base
- Validación corporativa

Muchas Gracias

¿Preguntas?

Autor: Adrián Puyo Olías

